
Deployment and Security Evaluation of a High-Availability Commercial VPN Infrastructure

1. Project Context

Modern enterprises that deliver network-based services to end users face a dual infrastructure challenge: they must operate and protect their own internal systems while simultaneously exposing service endpoints to the public internet. This combination of internal operations and external exposure creates a realistic environment in which the principles of network segmentation, high availability, and intrusion detection become not merely academic exercises but operational necessities.

The scenario for this project is the following: **AlgTech**, a fictional Algerian technology startup, operates a commercial VPN service. Subscribers authenticate through AlgTech's platform, establish encrypted tunnels through AlgTech's infrastructure, and route their internet traffic through AlgTech's exit nodes — a model directly comparable to services such as NordVPN or Mullvad. AlgTech employs approximately 50 staff members organized across the following departments:

- **IT Department**, subdivided into three teams:
 - *Engineering* — develops and maintains the VPN platform and internal systems
 - *Operations* — monitors infrastructure health and ensures service continuity
 - *Support* — handles subscriber and internal IT issues
- **HR Department** — manages employee records, recruitment, and administrative processes
- **Management** — oversees company direction, communicates with all departments

AlgTech's infrastructure serves two entirely distinct populations simultaneously. **External subscribers** interact with the VPN service through publicly reachable endpoints: they visit the subscription website, create accounts, authenticate, and connect their VPN clients. **Internal employees** access a single unified employee portal through which they conduct all their internal work. These two populations must be strictly separated at the network level — a subscriber must never be able to reach internal employee systems, and a compromise of any public-facing component must not translate into access to the internal corporate network.

You are tasked with designing, deploying, and evaluating the complete infrastructure supporting both sides of AlgTech's operations, with particular emphasis on the security boundaries between zones, the resilience of critical services, and the effectiveness of intrusion detection under realistic attack conditions.

2. Project Objectives

2.1. General Objective

Design, deploy, and evaluate a segmented, highly available infrastructure that simultaneously supports a public-facing VPN service and a protected internal corporate network. The system must remain operational under component failures and demonstrate effective detection of attacks targeting both the external service layer and the internal network boundary.

2.2. Specific Objectives

1. Design a **segmented network architecture** with clearly defined zones separating the public service layer, the internal corporate network, and the backend data tier, each governed by an explicit and documented trust policy.
2. Deploy a **gateway system** enforcing routing and stateful firewall rules at every zone boundary, ensuring that no unauthorized cross-zone traffic is possible under any condition.
3. Implement **service redundancy and load balancing** across the public-facing layer to ensure continuous VPN service availability despite individual node failures.
4. Deploy **two IDS sensors** at precisely defined network positions, each tasked with monitoring a specific traffic boundary and generating structured alerts on detected threats.
5. Deploy a **centralized monitoring and log aggregation platform** covering all infrastructure components, providing a unified operational view for the Operations team.
6. Conduct **controlled attack simulations** reflecting realistic threats against a public VPN provider and evaluate the detection accuracy and resilience of the infrastructure.
7. Produce a **structured technical report** analyzing architecture decisions, IDS sensor placement rationale, observed behavior under attack and failure, and identified weaknesses.

3. Required System Architecture

The infrastructure must follow a **multi-tier, segmented architecture** with strict and enforceable separation between the public service layer, the internal corporate network, and the backend data tier.

3.1. Network Segmentation

The network must be divided into the following mandatory zones:

- **Public Zone (DMZ):** The externally reachable layer of AlgTech’s infrastructure. This zone hosts the subscription and account management website, through which users sign up, manage their plans, and retrieve VPN configuration parameters. It also hosts the VPN authentication service, which validates subscriber credentials before a tunnel is established, and the VPN entry points through which authenticated subscribers connect their clients. All components in this zone are reachable from the simulated external network and must be treated as potentially hostile territory. A compromise of any component in this zone must not grant access to the internal network under any circumstances.
- **Internal Corporate Network:** The private zone accessible exclusively to AlgTech employees. This zone hosts the unified **employee portal** and the centralized directory service backing it. No path from the DMZ into this zone may exist unless explicitly authorized, documented, and justified in the design.
- **Backend Data Zone:** Hosts the replicated database servers storing subscriber account data and all internal company data. This zone must be unreachable from the DMZ. Only application servers in the DMZ and the internal zone may initiate connections to the backend, through strictly defined and documented paths. No direct administrative access to this zone from the DMZ is permitted.

You may introduce additional segments — such as a dedicated out-of-band management network for administrative SSH access to all nodes — if your design justifies it.

3.2. Gateway and Routing Layer

A dedicated gateway must govern all inter-zone traffic. It must:

- Route traffic between the simulated external network, the DMZ, the internal corporate network, and the backend data zone.
- Enforce stateful firewall rules implementing a **default-deny** policy between all zone pairs. Every permitted flow must be explicitly declared, justified, and documented in the report.
- Log all dropped packets and denied connection attempts with sufficient detail to support post-incident reconstruction.
- Apply NAT for outbound traffic where applicable.

3.3. Load Balancing Layer

A load balancer must front the public-facing application servers in the DMZ, distributing incoming subscriber requests across at least two instances. It must perform continuous health checks and automatically remove failed nodes from rotation. Failover following a node failure must be transparent to connected subscribers and must require no manual intervention.

3.4. Application Server Layer

3.4.1. Public-Facing Services (DMZ)

At least two stateless application server instances must be deployed in the DMZ to handle subscriber requests interchangeably. They must provide the following:

- **Subscription and Account Website:** Allows external users to register, log in, manage their subscription, and retrieve VPN configuration parameters. This is the primary public-facing interface of AlgTech's service.
- **VPN Authentication Service:** Validates subscriber credentials when a VPN client attempts to establish a tunnel. Must enforce account status checks — active subscription, no suspension — before authorizing a connection. Must apply rate limiting and account lockout after repeated failed attempts.

3.4.2. Employee Portal (Internal Corporate Network)

A separate application, deployed exclusively in the internal zone and inaccessible from the DMZ, must serve as the single unified interface for all AlgTech employees. Authentication is mandatory and must be backed by a centralized directory service managing employee identities, roles, and access rights. Once authenticated, employees have access to the following features according to their department and role:

- **Internal Mail:** A messaging system allowing employees to communicate internally. File attachments must be supported, with files stored in and retrieved from the shared file repository.
- **File Sharing:** A repository where employees can upload, organize, browse, and download files. Access permissions must be enforced at the file or directory level according to department membership.
- **IT Helpdesk:** A ticketing interface through which any employee can report a technical issue or submit a service request. Tickets are routed to and managed by the Support team.
- **HR Self-Service:** A module through which employees submit and track leave requests, consult their payslips, and access HR-related documents. Managed by the HR department.
- **VPN Status Dashboard:** A real-time operational view of AlgTech's VPN infrastructure, showing the health of VPN endpoints, active tunnel counts, and service-level indicators. Intended primarily for the Operations team.
- **Announcement Board:** A company-wide or per-department notice board through which Management and department leads publish communications to staff.

3.5. Database Layer

The database tier must be deployed in a **primary-replica replication configuration** with at least one replica node. A defined and tested failover procedure must promote the replica to primary when the primary node fails. No committed data must be lost during failover, and the system must resume normal read and write operations within a documented and minimized time window following the transition.

3.6. Intrusion Detection Layer

Two IDS sensors must be deployed at the following mandatory positions. Justify their placement in the report and explain what each sensor is capable of detecting given its position in the traffic path.

- **Sensor 1 — External Boundary (Internet-facing interface of the DMZ):** This sensor monitors all raw inbound traffic arriving from the simulated external network before it reaches any DMZ component. Positioned here, it has full visibility into attack traffic in its original, unmodified form. It is responsible for detecting inbound port scans and reconnaissance activity, volumetric flood attacks directed at the public zone, brute-force and credential stuffing patterns targeting the authentication service, and any known exploit signatures directed at the subscription website. This sensor sees the highest volume of traffic and must be configured with rules tuned to the threats most relevant to a public-facing VPN service.
- **Sensor 2 — Internal Boundary (Interface between DMZ and Internal Corporate Network):** This sensor monitors all traffic attempting to cross from the DMZ into the internal network. Under normal operating conditions, this interface should carry little to no traffic, as the firewall enforces a strict default-deny policy between these zones. Any traffic observed by this sensor therefore represents either a misconfiguration or an active lateral movement attempt by a DMZ-resident attacker. It is responsible for detecting unauthorized connection attempts from DMZ machines toward internal hosts, unexpected protocols or port usage crossing the boundary, and any scanning or probing behavior originating from within the DMZ.

3.7. Centralized Monitoring and Log Aggregation

A monitoring platform must provide the Operations team with a unified view of infrastructure health and security events. It must cover:

- **System metrics:** CPU, memory, disk, and network utilization for all nodes.
- **Service health indicators:** Availability status of all deployed services, with alerting on state changes.
- **IDS alert feed:** Alerts from both sensors must be forwarded to and displayed within the centralized platform, correlated by timestamp and source.
- **Log aggregation:** Logs from all components — gateway, load balancer, application servers, directory service, database nodes, and both IDS sensors — must be collected into a single queryable interface. It must be possible to filter logs by time range, source component, and severity.

4. Functional Requirements

1. **Zone Isolation:** No traffic originating from the DMZ must reach the internal corporate network unless explicitly permitted by a documented firewall rule. This isolation must hold even when a DMZ component is fully compromised and acting as an attacker. Sensor 2 must produce an alert for every violation attempt.
2. **Subscriber Service Continuity:** The subscription website and VPN authentication service must remain reachable when a single application server is taken offline. Failover must require no manual intervention and must be invisible to external users.
3. **Employee Portal Availability:** The employee portal must remain accessible to internal users when a single backend component fails. All portal features must continue to function normally following the failure.
4. **Database Failover:** Following primary database failure, the system must resume write operations within a documented and minimized time window. No committed subscriber or employee data must be lost during the transition.
5. **IDS Alert Coverage:** Every mandatory attack scenario must produce at least one structured alert from the appropriate IDS sensor. Alerts must appear in the centralized monitoring platform with a timestamp, a classification, and the source address of the detected activity.
6. **Log Traceability:** It must be possible to reconstruct the complete timeline of any attack or failure event from the centralized log system alone, without requiring direct access to individual node logs.

5. Attack Simulation Scenarios

Document each scenario with a clear methodology, the observed system behavior, IDS and monitoring evidence, and a critical post-scenario analysis identifying what was detected, what was not, and why.

5.1. Scenario 1 — Credential Stuffing Against the VPN Auth Service

From the simulated external network, perform a high-volume automated login attempt against the VPN authentication service using a list of generated credential pairs, simulating a real-world credential stuffing campaign. Document the response of the authentication service including any lockout or rate-limiting behavior, the alert generated by Sensor 1, and whether the attack is visible in the centralized log platform. Evaluate whether the collected evidence would be sufficient for an operator to identify the source and scope of the attack.

5.2. Scenario 2 — Volumetric Denial of Service Against the Public Zone

Direct a sustained flood of connection requests at the subscription website or the VPN authentication endpoint. Evaluate the behavior of the load balancer and application servers under saturation, the alert generated by Sensor 1, and whether legitimate subscriber requests continue to be served during the attack. Document any degradation in service quality, its duration, and the completeness of the event record in the log platform.

5.3. Scenario 3 — External Reconnaissance and Port Scanning

From the simulated external network, perform a systematic port scan of all addresses exposed in the DMZ. Document which services and ports are reachable, which are silently filtered, and which produce visible responses. Evaluate whether Sensor 1 detects and classifies the scan, and assess whether the exposed attack surface is consistent with the intended design. Identify any unintended exposures revealed by the scan.

5.4. Scenario 4 — Lateral Movement from the DMZ to the Internal Network

Simulate the scenario in which an attacker has compromised a machine in the DMZ. From this position, attempt to establish connections to hosts in the internal corporate network and the backend data zone, bypassing the application layer entirely. Document every blocked and permitted flow, the alerts generated by Sensor 2, and the firewall log entries produced during the attempt. Evaluate the completeness of the segmentation policy and identify any path that would allow a DMZ-resident attacker to reach internal resources.

5.5. Scenario 5 — Application Server Failure Under Active Load

Abruptly terminate one application server while a continuous stream of authentication requests is being submitted from the simulated external network. Document the behavior of the load balancer, the time elapsed before the failure is detected and traffic is rerouted, and any requests that fail during the transition window. Verify that the service recovers without manual intervention and that the failure event is visible in the monitoring platform.

5.6. Scenario 6 — Primary Database Failure

Interrupt the primary database node while both the subscriber-facing services and the employee portal are under active use. Execute the defined failover procedure and document the recovery time, any observable service interruption, and the consistency of all data records after the replica is promoted to primary. Verify that no committed data was lost and that the failover event is traceable in the log aggregation system.

Additional scenarios: Add at least one additional scenario of your own choosing. Relevant suggestions include DNS poisoning targeting the subscription website, session hijacking across the portal, log tampering, or privilege escalation within the employee portal.

6. Expected Deliverables

1. **Architecture Diagram:** A detailed diagram of the network topology showing all virtual machines, zones, interfaces, routing paths, component roles, and the precise positions of both IDS sensors. Zone boundaries and firewall enforcement points must be clearly labeled. The diagram must be precise enough to be independently reproducible.
2. **Written Report:** A structured document covering design rationale, component descriptions, firewall rule sets, IDS sensor placement justification, test methodology, and observed results. The report must include a critical analysis of each scenario's outcome, a discussion of what each IDS sensor did and did not detect, and an assessment of identified weaknesses and possible improvements.
3. **Configuration Files and Scripts:** All configuration files, deployment scripts, firewall rules, IDS rule sets, and automation code. These must be organized, commented, and sufficient to reproduce the full deployment independently.
4. **Log and Alert Evidence:** Exported logs and IDS alerts from both sensors, along with monitoring screenshots, collected during each test scenario and cross-referenced with the corresponding sections of the report.
5. **Live Demonstration:** A live or recorded demonstration of the system in normal operation, followed by at least one failure scenario and at least two attack scenarios, with the centralized monitoring platform and IDS alert feed visible throughout.

Good Luck!